

Task 14 — Investigación del Puerto UDP 123 (NTP)

Reporte técnico sobre el puerto UDP 123, su funcionamiento en NTP (Network Time Protocol), riesgos de seguridad y mecanismos de protección en distintos dispositivos.

1. ¿Qué es el puerto UDP 123?

El **puerto UDP 123** es el puerto estándar del protocolo **NTP**, usado para sincronizar la hora entre equipos en red.

- **Protocolo de transporte:** UDP
- **Puerto bien conocido:** 123
- **Servicio principal:** Sincronización de reloj del sistema
- **Uso típico:** clientes consultan servidores de tiempo confiables (por ejemplo, `pool.ntp.org` o servidores corporativos)

La sincronización horaria es crítica para:

- registros de auditoría (logs)
- certificados digitales y TLS
- autenticación (Kerberos, tokens con expiración)
- correlación de eventos de seguridad
- tareas programadas y sistemas distribuidos

2. Funcionamiento general de NTP

NTP intercambia marcas de tiempo para estimar:

- **offset:** diferencia entre reloj local y reloj de referencia
- **delay:** latencia de ida y vuelta
- **jitter:** variabilidad del retardo

Con estos valores, el cliente ajusta su reloj de manera gradual para evitar saltos bruscos.

Jerarquía de estratos (stratum)

- **Stratum 0:** fuentes primarias (GPS, relojes atómicos)
- **Stratum 1:** servidores conectados directamente a stratum 0
- **Stratum 2+ :** servidores que se sincronizan de estratos superiores

Mientras menor sea el estrato (más cercano a 1), normalmente mejor es la referencia temporal.

3. Flujo básico de comunicación

1. El cliente envía una solicitud NTP por UDP/123.

2. El servidor responde con su marca de tiempo y metadatos.
3. El cliente calcula offset y delay.
4. El cliente corrige su reloj local.
5. El proceso se repite periódicamente.

4. Riesgos de seguridad asociados al UDP 123

4.1 Ataques de amplificación/reflexión DDoS

Si un servidor NTP está mal configurado, puede responder con paquetes grandes a solicitudes pequeñas falsificadas (IP spoofing), amplificando tráfico hacia una víctima.

4.2 Manipulación de tiempo

Un atacante que logra inyectar respuestas NTP falsas puede desajustar el reloj del equipo objetivo, afectando autenticación, expiración de certificados y trazabilidad de logs.

4.3 Exposición innecesaria de servicio

Permitir NTP desde cualquier origen en internet aumenta la superficie de ataque y la posibilidad de abuso.

4.4 Dependencia de una sola fuente

Confiar en un único servidor de tiempo puede causar indisponibilidad o deriva excesiva si esa fuente falla.

5. Mecanismos de protección por dispositivo

5.1 Router

Objetivo

Mantener sincronizado el equipo de red sin exponerlo como servidor NTP público.

Buenas prácticas

- Configurar el router como **cliente NTP**, no como servidor abierto a internet.
- Permitir **salida** UDP/123 hacia servidores de tiempo confiables.
- Bloquear **entrada** UDP/123 desde WAN, salvo necesidad explícita.
- Desactivar funciones heredadas de monitoreo (**monlist**) en equipos antiguos.
- Mantener firmware actualizado.
- Registrar eventos de cambios de hora y reinicios.

Regla conceptual (firewall)

- ALLOW LAN -> NTP_SERVERS : UDP/123
- DENY WAN -> ROUTER : UDP/123

5.2 Laptop (Linux/Windows/macOS)

Objetivo

Sincronizar tiempo del sistema de forma segura y estable.

Buenas prácticas

- Usar clientes modernos (`systemd-timesyncd`, `chrony`, `ntpd` con configuración segura).
- Definir múltiples servidores NTP confiables.
- Aplicar firewall de host para aceptar solo tráfico relacionado/establecido.
- Evitar exponer el equipo como servidor NTP si no es necesario.
- Verificar estado de sincronización regularmente.

Verificación rápida en Linux

```
timedatectl status
timedatectl timesync-status
ss -ltn | grep ':123'
```

Interpretación básica:

- Si el equipo solo actúa como cliente, no debería quedar escuchando públicamente en 0.0.0.0:123 para redes no confiables.

5.3 Celular (Android/iOS)

Objetivo

Mantener hora exacta sin permitir abuso del dispositivo.

Buenas prácticas

- Mantener activada la hora automática de red.
- Actualizar sistema operativo y parches de seguridad.
- No usar apps de terceros para “forzar hora” salvo necesidad controlada.
- En entornos corporativos (MDM), restringir cambios manuales de fecha/hora.
- Usar VPN/red confiable en redes públicas para reducir exposición a manipulación de tráfico.

En general, el sistema móvil administra la sincronización internamente y no expone un servicio NTP abierto como servidor.

5.4 Otros dispositivos (IoT, cámaras, impresoras, servidores)

Recomendaciones comunes

- Cambiar credenciales por defecto.
- Limitar NTP a servidores internos o lista blanca de destinos.
- Segmentar red (VLAN) para dispositivos IoT.
- Aplicar ACLs para bloquear acceso entrante UDP/123 desde redes no confiables.
- Habilitar monitoreo y alertas de deriva de tiempo.

6. Señales de mala configuración

- Dispositivo exponiendo UDP/123 a internet sin requerimiento.
- Deriva de tiempo frecuente (saltos grandes de reloj).
- Errores TLS/certificados por fecha incorrecta.
- Logs con marcas de tiempo incoherentes.
- Alto volumen de tráfico NTP inesperado.

7. Checklist de endurecimiento (resumen)

- ☐ Definir fuentes NTP confiables (mínimo 2-3)
- ☐ Bloquear entrada UDP/123 desde internet
- ☐ Permitir solo salida necesaria UDP/123
- ☐ Actualizar firmware/SO del dispositivo
- ☐ Revisar periódicamente estado de sincronización
- ☐ Monitorear anomalías de tráfico y deriva

8. Conclusión

El puerto UDP 123 es esencial para la operación segura de sistemas modernos porque mantiene la coherencia temporal. Sin embargo, una configuración deficiente puede habilitar abuso en ataques DDoS o manipulación del reloj. La estrategia recomendada es sencilla: usar NTP como **cliente controlado**, restringir exposición de UDP/123, mantener equipos actualizados y monitorear continuamente la salud de la sincronización.

Es evidente que como en todo puerto y servicio, las vulnerabilidades existen y la clave de la seguridad es manejar bien las reglas de conexión tanto de entrada, como de salida.